

SIMATS ENGINEERING (SAVEETHA SCHOOL OF ENGINEERING)
Department of Computer Science and Engineering

ASSESSMENT TOOL 2 - Scenario-Based

Course Code:	CSA5802	Course Title:	DEVSECOPS ENGINEERING AND APPLICATION SECURITY
CO Assessed:	CO1 – Precision (BL1, BL2, BL3)	Assessment:	Assessment Tool 2
Weightage:	30% of CIA	Total Marks:	100
CO1 Statement:	Team-Based Concept Association, Knowledge Competition and Collaborative Learning.		
Student Name:	K.Yalla Reddy	Reg. No.:	192465047
Section / Batch:		Date:	

Instructions to Students

- Each team receives one unique industry case study.
- Analyze the scenario and complete all investigation tasks.
- Prepare a 5-minute presentation and one consolidated report.
- Support very recommendation with technical justification.

Question Type	Focus Area	Questions	Marks
Concept Mapping	Scenario-Based CollaborativeAnalysis	Q1	Q1 –100
GRAND TOTAL:		100 Marks	

SECTION A

University ERP Portal

A university ERP system manages admissions, examinations, attendance, fee payments and student records for over 20,000 students. Development focuses primarily on new functionality. Password reset links never expire, uploaded files are not validated, security testing occurs only after deployment and user activity logs are rarely reviewed.

The administration recently discovered unusual changes in student records and suspects weaknesses in access control and authentication.

Investigation Questions

1. identify at least five security risks.
2. Identify at least five vulnerabilities and classify each as High, Medium or Low.
3. List possible cyber threats and explain their impact.
4. Prepare a DevOps vs DevSecOps comparison table (minimum eight points).
5. Recommend five OWASP security best practices.
6. Explain the business impact if these issues remain unresolved.
7. Create a concept map linking Risk → Vulnerability → DevSecOps Practice → Business Benefit.
8. Prepare a five-minute presentation summarizing your findings.

Code of Conduct

I K.Yalla Reddy(192465047) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the Student: _____

TEAM – 6

Venkateswarlu B (192465033)

Yalla reddy K (192465047)

Background :

Auniversity ERP system manages admissions, examinations, attendance, fee payments and student records for over 20,000 students. Development focuses primarily on new functionality. Password reset links never expire, uploaded files are not validated, security testing occurs only after deployment and user activity logs are rarely reviewed. The administration recently discovered unusual changes in student records and suspects weaknesses in access control and authentication. Investigation Questions

1. Identify at least Five Security Risks

S.No Security Risk Explanation

1 Unauthorized

Access Attackers may access student or staff accounts without permission. 2 Data Tampering Student records, attendance, marks, or fee details may be modified illegally.

3 Malware Upload Malicious files can be uploaded because uploaded files are not validated.

4 Account Takeover Permanent password reset links allow attackers to hijack user accounts.

5 Insider Threat Employees or administrators may misuse their privileges. 6 Data Leakage Confidential student information may be exposed. 7 Service Disruption Cyberattacks can make the ERP unavailable to students and staff.

2. Identify at least Five Vulnerabilities and Classify Them

Vulnerability Risk Level Reason

Password reset links never expire **High** Attackers can reuse old reset links to gain access. Uploaded files are not validated **High** Malicious files or web shells can be uploaded. Weak access control **High** Unauthorized users may access sensitive records. Security testing only after deployment **Medium** Vulnerabilities remain unnoticed during development.

User activity logs are rarely reviewed **Medium** Suspicious activities may not be detected quickly.

Lack of Multi-Factor Authentication

(MFA) **High** Password theft can easily lead to account compromise.

Poor session management **Medium** Sessions may remain active for long periods. **3. Possible Cyber Threats and Their Impact**

Cyber Threat Impact

SQL Injection Database records can be stolen or modified.

Cyber Threat Impact

Phishing User credentials can be stolen.

Ransomware Student records become inaccessible until ransom is paid. Malware Upload Server can be infected and controlled by attackers. Privilege Escalation Normal users gain administrator privileges.

Insider Attack Employees misuse system access.

Brute Force Attack Weak passwords can be cracked.

Denial of Service (DoS) ERP becomes unavailable during admissions or examinations. **4.**

DevOps vs DevSecOps Comparison

DevOps DevSecOps

Security is added after development. Security is integrated from the beginning. Focus on speed and automation. Focus on speed, automation, and security. Testing occurs mainly after

deployment. Continuous security testing throughout development. Developers are mainly responsible. Developers, Security Team, and Operations work together.

Manual security checks. Automated security scanning.

Vulnerabilities are detected late. Vulnerabilities are detected early. Higher cost to fix issues. Lower cost due to early detection. Security is a separate process. Security is part of the entire SDLC. Slower response to threats. Faster response to vulnerabilities.

5. Five OWASP Security Best Practices

1. Strong Authentication

- Enable Multi-Factor Authentication (MFA).
- Use strong password policies.

2. Secure Access Control

- Follow the Principle of Least Privilege.
- Restrict user permissions based on roles.

3. Validate All Inputs

- Validate uploaded files.
- Reject malicious file types.

4. Continuous Security Testing

- Perform Static Application Security Testing (SAST).
- Perform Dynamic Application Security Testing (DAST).
- Conduct penetration testing before deployment.

5. Monitor and Review Logs

- Review system logs regularly.
- Detect suspicious login attempts and unauthorized activities.

6. Business Impact if Issues Remain Unresolved

1. Data Breach

Sensitive student and staff information may be leaked.

2. Financial Loss

The university may lose money due to cyberattacks, recovery costs, and legal penalties.

3. Reputation Damage

Students and parents may lose trust in the university.

4. Operational Disruption

Admissions, exams, and fee payments may stop during attacks.

5. Legal and Compliance Issues

The university may violate data protection regulations.

6. Academic Integrity Issues

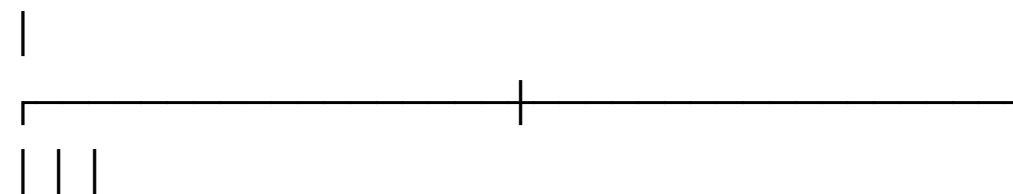
Marks and attendance records could be altered.

7. Increased Recovery Costs

Fixing problems after an attack is more expensive than preventing them.

7. Concept Map

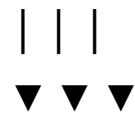
SECURITY RISK



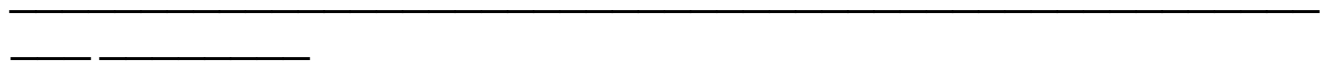
Unauthorized Access Malware Upload Data Tampering



Weak Access Control No File Validation Expired Reset Links



DevSecOps Practices (Security Controls)



- ✓ Multi-Factor Authentication (MFA)
- ✓ Role-Based Access Control (RBAC)
- ✓ Secure File Validation
- ✓ Secure Password Reset

✓ Continuous Security Testing (SAST & DAST)

✓ Continuous Log Monitoring

✓ Secure CI/CD Pipeline

✓ Regular Vulnerability Scanning

|



BUSINESS BENEFITS

✓ Better Data

Security

✓ Faster Threat Detection

✓ Reduced Cyber Attacks

✓ Lower Maintenance Cost

✓ Regulatory Compliance

✓ Improved Student Trust

✓ Higher System Availability

✓ Secure University Operations

8. Five-Minute Presentation

Slide 1 – Title

University ERP Portal Security Analysis

- Team 4
- DevSecOps and Network Security

Slide 2 – Background

- ERP manages admissions, attendance, exams, fee payments, and student records. ● Supports over 20,000 students.
- Security weaknesses were identified.
- Unauthorized changes were detected.

Slide 3 – Security Risks

- Unauthorized access
- Data tampering
- Malware upload
- Account takeover
- Insider threats
- Data leakage

Slide 4 – Vulnerabilities

- Password reset links never expire (High)
- No file validation (High)
- Weak access control (High)
- Late security testing (Medium)
- Logs rarely monitored (Medium)

Slide 5 – Cyber Threats

- SQL Injection
- Phishing
- Ransomware
- Malware
- Privilege Escalation
- Denial of Service

Slide 6 – DevOps vs DevSecOps

- DevOps focuses on speed.
- DevSecOps integrates security from the beginning.
- Continuous security testing.
- Automated vulnerability scanning.

Slide 7 – OWASP Best Practices

- Multi-Factor Authentication
- Secure Access Control
- Input Validation
- Continuous Security Testing
- Log Monitoring

Slide 8 – Business Impact

- Data breaches
- Financial losses
- Reputation damage
- Operational disruption
- Legal issues

Slide 9 – Conclusion

The University ERP Portal has several critical security weaknesses. Implementing DevSecOps practices and following OWASP recommendations will improve security, protect sensitive student information, reduce cyber risks, and ensure reliable university operations.

RUBRICS FOR CALCULATION

Criteria	Wt.	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20%	Clearly understands the problem and accurately identifies all requirements	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30%	Accurately applies appropriate concepts to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem-Solving Approach	20%	Logical, well-structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20%	Completely correct solution with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution
Clarity	10%	Clear, well-organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand

Rubrics:

Criteria	Weightage	Awarded Marks	Total Marks (100)
Understanding of Concepts	25%		
Experimental Design	30%		
Use of Tools	20%		
Analysis of Results	15%		
Documentation	10%		
Total per Question	100 Marks		

— 100

Faculty In-charge	Course Coordinator	Head of Department
Signature: _____	Signature: _____	Signature: _____
Date: _____	Date: _____	Date: _____

